

DISSERTATION CASE STUDY

ON

**SRS FOR Designing a Software
Reference Architecture to Enhance Privacy
and Security in Electronic Health Records**

Software Requirements Specification (SRS)

Source Paper

Design a Software Reference Architecture to Enhance Privacy and Security in Electronic Health Records

1. Introduction

1.1 Purpose

This study proposes a Software Reference Architecture (SRA) tailored for Electronic Health Records (EHRs) that incorporates security and privacy considerations, intended to enhance the development of these systems.

The purpose stated in the paper is:

To propose a Software Reference Architecture (SRA) for Electronic Health Records (EHRs) with security and privacy considerations.

1.2 Scope

Healthcare services and organizations rely on Electronic Health Records (EHRs) to manage, store, and transmit patient data records.

and

"This paper aims to propose a Software Reference Architecture (SRA) for Electronic Health Records (EHRs) that integrates security and privacy requirements.

Therefore, the scope explicitly covers Electronic Health Record systems with emphasis on privacy and security.

1.3 Intended Users

Patient
Healthcare Professional
Healthcare Manager
EHR Administrator
Care Professional
Laboratory
Government
Data Protection Officer (DPO)
Other EHR systems
Insurance Company
Secretary
Research Company

2. Overall Description

2.1 Product Functions

- Manage patient electronic records
 - Access patient medical records
 - Store clinical assessment results
 - Manage patient profiles
 - Manage user accounts
 - Reporting
 - System analysis
 - Authentication
 - Audit control
 - Consent management
 - Emergency access
 - Access control
 - Secure transmission
 - Data integrity
 - Automatic logoff
 - Anonymization
-

2.2 Dependencies

- GDPR
 - HIPAA
 - ISO 18308:2011
-

3. Functional Requirements

ID	Requirement
FR-001	The system shall manage patient electronic records.
FR-002	The system shall provide healthcare professionals access to patient medical records.
FR-003	The system shall allow healthcare providers to insert clinical notes.
FR-004	The system shall provide tools for prescribing medications.
FR-005	The system shall manage prescriptions.
FR-006	The system shall check for potential drug interactions or allergies.
FR-007	The system shall provide clinical decision support tools.
FR-008	The system shall provide reporting tools.
FR-009	The system shall analyze data to monitor population health trends.
FR-010	The system shall store laboratory data.
FR-011	The system shall store radiology reports.
FR-012	The system shall store diagnostic imaging results.
FR-013	The system shall integrate clinical assessment data into the patient's records.
FR-014	The system shall manage patient profiles.
FR-015	The system shall manage patient demographic information.
FR-016	The system shall maintain patient medical history.
FR-017	The system shall allow users to access account details.
FR-018	The system shall provide user account information.
FR-019	The system shall support interoperability.
FR-020	The system shall support data retention and archiving.
FR-021	The system shall support backup and disaster recovery.
FR-022	The system shall monitor and record access to EHR systems.
FR-023	The system shall track user activities.
FR-024	The system shall maintain audit logs.
FR-025	The system shall track data access.
FR-026	The system shall identify security incidents.
FR-027	The system shall protect Protected Health Information (PHI) from unauthorized alteration or destruction.
FR-028	The system shall safeguard Protected Health Information (PHI).
FR-029	The system shall encrypt data during transmission between systems.
FR-030	The system shall ensure secure access control through authentication.
FR-031	The system shall automatically terminate inactive user sessions.
FR-032	The system shall regulate and restrict user permissions.
FR-033	The system shall allow only authorized individuals to view or modify patient records.
FR-034	The system shall provide emergency access to critical patient information.
FR-035	The system shall enable retrieval of user data during emergencies.

FR-036	The system shall support anonymization of personal data.
FR-037	The system shall obtain patient consent for data collection, use, and disclosure.
FR-038	The system shall support informed consent practices.
FR-039	The system shall enable users to manage access to their health information.
FR-040	The system shall enable users to authorize access to their health information.

4. Non-Functional Requirements

ID	Category	Requirement
NFR-001	Privacy	The system shall maintain the privacy and security of patients' sensitive data.
NFR-002	Security	The system shall ensure the confidentiality, integrity, and availability of healthcare information.
NFR-003	Security	The system shall protect data from unauthorized alteration or destruction.
NFR-004	Privacy	The system shall protect patient confidentiality and ensure data privacy.
NFR-005	Ethics	The system shall uphold ethical standards in healthcare information management.
NFR-006	Compliance	The system shall comply with regulatory, legal, and ethical requirements for patient privacy protection.
NFR-007	Compliance	The system shall ensure compliance with industry regulations and privacy laws.
NFR-008	Interoperability	The system shall ensure seamless data exchange between systems for comprehensive patient care.
NFR-009	Scalability	The system shall adapt to growing demands.
NFR-010	Availability	The system shall ensure service continuity in adverse scenarios.
NFR-011	Reliability	The system shall safeguard against data loss.
NFR-012	Compliance	The system shall support compliance through data retention and archiving.
NFR-	Security	The system shall keep sensitive information confidential during

013		transmission.
NFR-014	Accountability	The system shall enhance transparency and accountability in EHR usage.
NFR-015	Privacy	The system shall respect patient privacy preferences and establish trust in data-sharing practices.
NFR-016	Privacy	The system shall reduce the risk of re-identification when using patient data.

5. Constraints

Only constraints **explicitly stated by the authors** are included.

ID	Constraint
C-001	The system shall ensure compliance with GDPR.
C-002	The system shall ensure compliance with HIPAA.
C-003	The system architecture shall align with ISO 18308:2011.

6. Assumptions

Only assumptions **explicitly mentioned by the authors** are included.

ID	Assumption
A-001	Existing architectural solutions do not comprehensively address privacy and security for EHR systems.
A-002	Privacy and security are essential aspects of EHR systems.
A-003	Healthcare organisations require systematic incorporation of security and privacy requirements.